

Corporate AI Policies

CompTIA SecAI+: AI Security Certification Complete Exam Prep 2026 | Section 26: Compliance Frameworks and Standards

1. Why Internal Policy Is the Last Mile of Governance

International frameworks and laws define what organizations must achieve in the abstract. A corporate AI policy is the instrument that closes the gap between abstract requirement and observable behavior. Without it, the EU AI Act's prohibition on prohibited AI uses is a legal obligation with no translation into day-to-day employee decisions. NIST AI RMF 1.0's GOVERN function is a framework principle with no organizational owner. ISO/IEC 42001 certification is a management system structure with no concrete behavioral rules.

A well-designed corporate AI policy answers three questions that frameworks and laws leave to the organization: which AI uses are permitted and which are prohibited given our specific risk tolerance and business context; who is accountable for AI governance decisions at each level of the organization; and what happens when someone violates the policy. The answers to these questions — specific, enforced, and understood by employees — are what makes external standards real.

An analogy: a building fire code specifies what fire safety outcomes a building must achieve. A corporate safety policy specifies which exits employees use in their specific building, who is the floor warden, and what happens if someone props open the fire door. Both are necessary; neither substitutes for the other.

2. The Seven Elements of a Mature AI Policy

Organizations with mature AI governance programs have converged on a common policy structure. Practitioners should be able to identify gaps when examining an organization's AI policy against these elements:

Policy Element	What It Covers	Common Gap
Purpose and scope	What AI activities the policy covers; who is subject to it (employees, contractors, vendors)	Scope that excludes contractors or third-party AI users
AI classification	Risk-tiered categorization of AI systems, mirroring EU AI Act approach	Binary permitted/prohibited without risk tiers
Permitted and prohibited uses	Explicit approved uses and absolute prohibitions	Permitted list but no prohibition list; or vice versa
Governance roles	AI risk owner, AI review board, business unit AI leads, and responsibilities	Roles documented but not filled or exercised
Procurement requirements	What vendors must demonstrate before AI tool approval	Procurement review exists but is routinely bypassed
Human oversight requirements	Which AI-assisted decisions require human review before	Human oversight required but not technically enforced

	action	
Accountability and enforcement	Consequences for policy violation; escalation paths	Policy exists with no enforcement mechanism

A policy that addresses all seven elements but lacks enforcement for any of them is better than a policy that ignores the element entirely — but only marginally. The exam tests both policy design and the mechanisms that make policy operational.

3. Generative AI Acceptable Use Policies — The New Critical Sub-Policy

As generative AI proliferated through 2023–2024, a specialized sub-category of AI policy became critical: the Generative AI Acceptable Use Policy (GenAI AUP). The trigger was a series of high-profile incidents in which employees transmitted sensitive organizational data to external AI services without understanding the data governance implications.

A mature GenAI AUP addresses four specific concerns:

- Data classification restrictions: which data classifications (confidential, restricted, personally identifiable, health-related, privileged legal communications) may not be input into external AI services, regardless of which service.
- Approved tool list: which AI tools are approved for use, differentiated by use case — a coding assistant approved for general code may not be approved for cryptography or authentication code review.
- Mandatory human review: which categories of AI-generated content require human expert review before use — regulatory filings, client communications, legal documents, code destined for security-critical functions.
- Labeling requirements: when and how AI-generated content must be disclosed in internal and external communications, meeting regulatory expectations for transparency.

Organizations that implemented GenAI AUPs reactively — after incidents — typically did so incompletely, focusing on approved tools without addressing data classification restrictions. The more effective proactive approach starts with data classification and derives tool restrictions from it.

4. Real-World Incident: Samsung and the Limits of Policy Without Enforcement

Samsung Proprietary Code Leak via ChatGPT (2023): Within weeks of Samsung permitting engineers to use ChatGPT for work tasks, three separate employees transmitted proprietary semiconductor manufacturing source code to the platform. One used it to debug chip source code; another to optimize code for identifying database errors; a third to convert meeting notes. All three incidents involved ChatGPT's default data handling practice at the time — that inputs could be used to improve the model. Samsung had not provided data classification training specific to external AI services, had no technical controls blocking transmission of confidential data to AI endpoints, and had no DLP rules detecting proprietary code leaving corporate endpoints to AI service APIs. Samsung's response — an immediate ban on generative AI on corporate devices — illustrates reactive policy implementation. The lesson: policy without detection and enforcement is aspiration without assurance.

The deeper governance insight from Samsung is about the gap between policy intent and operational reality. Even after a comprehensive AI policy exists, employees may not know which of their data falls under which classification, may not understand that an external AI service's terms of service permit training on user inputs, and may not perceive a compliance obligation when using a tool that feels as natural as a search engine. Policy operationalization requires three things that Samsung lacked: training, technical controls, and detection.

5. Red Team Perspective: Social Engineering Past AI Policy Controls

AI policy compliance failures often stem not from deliberate violation but from ambiguity, inadequate training, and approval processes that create incentives for shadow adoption. A social engineering assessment targeting AI policy controls would test:

- Urgency pressure: can an employee be convinced to input confidential data into an unapproved AI tool if a request is framed as time-sensitive? ('I know the approved tool takes three days for review, but the client presentation is tomorrow')
- Ambiguity exploitation: does the policy's data classification language create grey areas employees resolve in favor of convenience rather than caution?
- Approval fatigue: does the AI tool procurement review process take long enough that business units develop workarounds — departmental credit cards for unapproved subscriptions, personal accounts for sensitive tasks?
- Training gaps: can employees articulate which data classifications are prohibited from external AI tools without consulting the policy document? If not, the training component has failed.

Red team findings in this domain are typically not about malicious actors but about structural incentives. Defenders address this by creating fast-track approval paths for low-risk AI tools (removing the incentive for workarounds), implementing technical controls that enforce restrictions independent of employee judgment, and ensuring training is scenario-specific rather than abstract.

6. AI Governance Bodies: Councils, Review Boards, and Ethics Committees

Large organizations typically create dedicated governance bodies for AI oversight. Understanding the purpose and level of each body is an exam-relevant distinction:

Governance Body	Level	Primary Function
AI Steering Committee / AI Council	Executive	AI strategy, major AI investment decisions, enterprise risk governance for AI
AI Review Board	Operational	Review specific AI deployment proposals against policy; assess impact assessments; approve AI procurement
AI Ethics Committee	Advisory	Evaluate AI systems for ethical implications; includes diverse stakeholders (legal, compliance, HR, community representatives)
Model Risk Committee	Technical / Risk	Validate high-risk models before deployment; ongoing monitoring of model performance and bias

Data Governance Council	Cross-functional	AI training data classification, data quality standards, data subject rights management
-------------------------	------------------	---

The structure varies by organization size — a startup may combine these into a single AI governance forum, while a multinational may have all five. What matters for exam purposes is recognizing what each body does and at which level it operates. Policy without a governance body to review decisions is unenforceable; a governance body without a policy to enforce has no decision criteria.

7. Technical Enforcement: Making Policy Operational

A corporate AI policy that relies entirely on employee judgment and self-reporting is not a security control — it is a disclosure document. Effective AI policy is enforced through technical controls that limit or detect non-compliant behavior independent of employee intent:

- Network controls: URL filtering and DNS policy blocking access to non-approved external AI service endpoints. Employees cannot access unapproved tools even if they want to.
- Data Loss Prevention (DLP): rules detecting transmission of data classified as confidential or above to AI service API endpoints. Flags or blocks the data transfer before it leaves the corporate perimeter.
- Cloud Access Security Broker (CASB): tools such as Microsoft Defender for Cloud Apps, Netskope, and Zscaler CASB detect and control shadow AI adoption by identifying traffic to known AI service endpoints. Provides visibility into unapproved AI tool usage across the organization.
- Procurement system integration: AI tool access provisioning tied to procurement review completion — technical access requires an approved procurement record.
- Audit logging: comprehensive logging of AI tool usage for post-incident investigation and compliance reporting.

Policy without technical enforcement: A policy that can only be violated by an employee who is both aware of it and chooses to ignore it will be violated continuously by employees who are simply unaware, untrained, or working under time pressure. Technical controls enforce policy regardless of employee knowledge state.

8. Developer-Facing AI Policy: A Distinct Character

Developer teams interact with AI in ways that general employees do not — using AI coding assistants that have persistent access to code repositories, generating code that enters production systems, and processing technical data that may include credentials, proprietary algorithms, or customer data. Developer AI policy must be specific enough to generate decisions, not just principles.

Key developer AI policy provisions:

- Approved AI coding assistant tools: specify which tools are approved (GitHub Copilot Enterprise, Amazon Q Developer, or similar enterprise tools with appropriate data governance controls) and which are prohibited (consumer-grade tools without enterprise data agreements).

- Code review requirements: AI-generated code must be reviewed by a qualified human developer before merge — no automated pipeline that bypasses human review for AI-generated commits.
- Security-critical code restrictions: AI tools may not be used to generate cryptographic functions, authentication and authorization logic, or security-critical code without expert security review, regardless of which approved tool is used.
- Context data restrictions: production credentials, API keys, customer data, and proprietary algorithms may not be provided as context to any AI coding assistant — even approved enterprise tools.
- AI supply chain controls: AI-generated code must pass the same SAST/DAST pipeline as human-written code; no bypass for code because its origin is an AI tool.

9. Prohibited AI Uses — The Explicit Prohibition List

An AI policy that only describes approved uses leaves employees without guidance on hard cases. Explicit prohibition lists remove ambiguity and create clear behavioral expectations. Common prohibited uses that practitioners should be able to identify:

- Generating synthetic voices or images that impersonate real individuals without explicit consent — relevant for deep-fake creation and social engineering content.
- Processing personal health data through external AI services without HIPAA-compliant data handling agreements.
- Making final employment decisions (hiring, termination, promotion) based solely on AI output without human review — prohibited under GDPR Article 22 and many state laws.
- Submitting AI-generated content in regulatory filings or legal proceedings without expert review and human sign-off — creates professional and legal liability.
- Using non-approved AI tools to process data classified as confidential or above — the core shadow AI prohibition.
- Using AI to generate misleading content about the organization's products, services, or financial performance.

The exam tests whether candidates can identify both what makes a use prohibited and which policy element creates the prohibition. Framing prohibited uses as absolute limits — rather than risk-based considerations — creates clearer behavioral expectations and stronger enforcement positions.

10. Policy Lifecycle: AI Policy Is Not a One-Time Document

The AI landscape changes faster than most governance cycles. Generative AI capabilities in 2026 are materially different from those in 2023 when many organizations first drafted AI policies. Policy lifecycle management requires four mechanisms:

- Annual comprehensive review: aligned with changes in regulation (EU AI Act implementation timelines, sector-specific regulatory guidance), technology capability, and organizational risk appetite.
- Event-triggered reviews: significant AI incidents within the organization or industry trigger policy review — the policy should evolve in response to new failure modes, not wait for the annual cycle.

- Change management process: policy updates must be communicated to all in-scope personnel, with re-training where required. A policy updated but not communicated is effectively unchanged from a behavioral standpoint.
- Version control and archiving: superseded policy versions archived with effective dates for audit purposes — regulators and auditors will ask what policy was in force at the time of an incident.

External triggers for policy review include sector regulatory guidance (SEC AI risk guidance, OCC model risk management updates, FCA AI guidance, EBA AI framework publications) and legislative changes in jurisdictions where the organization operates. AI policy teams should subscribe to regulatory update feeds from all relevant sector regulators.

11. Benchmarking: What Strong AI Policies Look Like

Reviewing published responsible AI policies from peer organizations provides benchmarking data and identifies elements missing from an organization's own policy. Noteworthy published frameworks include:

- Microsoft Responsible AI Standard v2: detailed internal standard covering fairness, reliability, privacy, security, inclusiveness, transparency, and accountability — with specific implementation requirements for each principle.
- Google AI Principles: high-level principles with sector-specific implementation guidance; supplemented by more detailed internal standards.
- IBM AI Ethics Board publications: published principles with governance structure documentation.
- US OMB Memorandum M-24-10: federal agency AI governance requirements — relevant for organizations working with US government or subject to similar accountability obligations.
- UK AI Procurement Guidelines: procurement-focused AI governance framework for organizations in the UK public sector or working with UK government.
- NIST AI RMF Playbook: includes policy templates adaptable for organizational use.

Strong policies share a common characteristic the exam tests: they are specific enough to generate decisions, not just guidance on how to think about decisions. A policy that says 'use AI responsibly' is not actionable; a policy that says 'no confidential data may be input to any external AI service without procurement review and a signed data processing agreement' generates a decision for every ambiguous situation.

12. Exam Angle: Policy as a Control Category

SecAI+ exam questions on corporate AI policy appear in scenario format: an organization has an AI policy but an incident occurs — what control was missing? The exam tests recognition of five policy failure modes:

Failure Mode	Root Cause	Missing Control
Policy violation through shadow AI	Procurement process creates bypass incentive	Fast-track approval + CASB technical detection
Data sent to unauthorized AI service	No data classification training for AI context	DLP rules + mandatory training with assessment

AI makes consequential decision without review	Human oversight requirement not technically enforced	Workflow gate requiring human sign-off before action
Policy violation not detected	No monitoring of AI tool usage	Audit logging + CASB usage visibility
Policy violation not addressed	No enforcement mechanism or consequence	Defined enforcement process with clear consequences

A secondary exam theme: policy governs employee behavior; it does not govern how a third-party AI vendor's model behaves. Third-party risk requires procurement controls (requiring contractual terms), security assessments, and ongoing vendor management — not just internal policy.

Key Terms Glossary

Term	Definition
Corporate AI policy	Internal organizational document translating external AI governance requirements into specific permitted uses, prohibitions, governance roles, and enforcement mechanisms.
Generative AI Acceptable Use Policy (GenAI AUP)	Specialized sub-policy specifying which data classifications may not be input to external AI services, which AI tools are approved, and when human review of AI output is mandatory.
AI Steering Committee	Executive-level governance body setting AI strategy, approving major investments, and ensuring AI risk representation in enterprise risk governance.
AI Review Board	Operational-level governance body reviewing specific AI deployment proposals against policy requirements and approving AI procurement.
Shadow AI	Unapproved adoption of AI tools by employees or business units outside of formal procurement review — the primary enforcement gap in AI policy programs.
Cloud Access Security Broker (CASB)	Tool detecting and controlling shadow AI adoption by identifying employee traffic to known AI service endpoints; enforces AI tool use policy at the network layer.
Data Loss Prevention (DLP)	Technical control detecting and blocking transmission of data classified at or above a defined threshold to unauthorized destinations, including AI service endpoints.
AI Ethics Committee	Advisory governance body evaluating AI systems for ethical implications, typically including diverse stakeholders from legal, compliance, HR, and affected communities.
Policy lifecycle management	The ongoing process of reviewing, updating, and communicating corporate AI policy in response to regulatory changes, technology evolution, and incident learning.
Prohibited use	An absolute behavioral prohibition in an AI policy — uses framed as hard limits rather than risk-based considerations, creating clear enforcement positions.

Quick Revision Checklist

- A corporate AI policy translates external standards and laws into specific organizational behavioral rules — without it, frameworks remain abstract.
- Mature AI policies address seven elements: purpose/scope, AI classification, permitted/prohibited uses, governance roles, procurement requirements, human oversight, and enforcement.
- GenAI AUPs must address data classification restrictions, approved tool lists, mandatory human review requirements, and AI content labeling.
- The Samsung (2023) incident demonstrates policy without technical enforcement — three separate data leaks before detection; ban implemented reactively.
- Shadow AI is the primary enforcement gap: approval processes that are slow or burdensome create incentives for workarounds.
- Technical enforcement controls include network URL filtering, DLP rules for AI endpoints, CASB shadow AI detection, and procurement system integration.
- Developer AI policy must address approved coding assistants, code review requirements for AI-generated code, security-critical code restrictions, and AI supply chain controls.
- Prohibited use lists should be framed as absolute limits, not risk-based considerations, to create clear behavioral expectations.
- Policy lifecycle requires annual comprehensive review, event-triggered reviews, change management communication, and version archiving.
- Policy failure modes: shadow AI, uncontrolled data transmission, no human oversight enforcement, no detection, no consequence — each has a specific missing control.

10 Exam-Based MCQs — Corporate AI Policies

Test yourself after reading. These questions mirror the scenario-heavy, distractor-rich style of the CompTIA SecAI+ exam. Read every explanation including for questions you answered correctly.

Q1. *Scenario:* A professional services firm implemented a comprehensive AI governance policy three months ago. The policy explicitly prohibits use of unapproved AI tools for processing client data classified as confidential. The CISO discovers during a network audit that a business unit purchased an unapproved AI analytics tool using a departmental credit card and has been processing client financial projections through it for 11 weeks. Three months after implementing a comprehensive AI governance policy, the CISO discovers that a business unit has been using an unapproved AI analytics tool, purchased with a departmental credit card, to process client financial data. The AI policy explicitly prohibits use of unapproved AI tools for processing confidential data. Which control gap BEST explains why the policy failed?

- A) The AI policy did not include a human oversight requirement for financial data processing
- B) The organization lacked technical enforcement controls — CASB shadow AI detection and DLP rules — to detect or block unapproved AI tool usage at the network layer
- C) The AI policy was not approved by top management, making it legally unenforceable
- D) The business unit's employees had not read the AI policy documentation

Answer: B **Explanation:** B is correct: this is the archetypal 'policy without technical enforcement' failure.

The policy prohibits the behavior, but without technical controls — CASB detection of traffic to unapproved AI endpoints, DLP rules blocking confidential data transmission, or procurement controls preventing tool access — employees can violate the policy without detection. The gap is not in policy content but in enforcement infrastructure. A is wrong: the issue is data going to an unapproved tool, not absence of human oversight within an approved workflow. C is wrong: there is no indication top management approval was absent; even if there were, lack of approval is not the root cause of shadow AI adoption. D is wrong: whether employees read the policy is an awareness gap, but technical controls enforce policy independent of employee knowledge state.

Q2. Scenario: *A regional bank's AI policy requires that all AI-generated credit analyses must be reviewed and approved by a qualified loan officer before they inform any lending decision. During a compliance audit, the auditor observes that loan officers are clicking 'approved' on AI analyses within an average of 8 seconds of receiving them, without any documented review activity. The workflow technically satisfies the 'approval required' requirement as designed. A financial firm's AI policy requires human review before any AI-generated credit analysis is used in a lending decision. An audit reveals that loan officers are consistently approving AI-generated analyses without conducting meaningful review — clicking 'approved' within seconds of receiving the analysis. What type of failure does this represent, and what control addresses it?*

- A) A policy design failure; the fix is to rewrite the policy to add more specific human review guidance
- B) A training failure; mandatory refresher training on the human oversight requirement will resolve the pattern
- C) A technical enforcement failure — the workflow allows the 'approved' click without requiring evidence of review; the fix is a workflow gate requiring the reviewer to document their assessment before proceeding
- D) An accountability failure; the fix is disciplinary action against the loan officers who approved without reviewing

Answer: C **Explanation:** C is correct: when a required human review can be satisfied by clicking a button without any substantive action, the control is not operating as designed. The technical fix is a workflow gate that requires the reviewer to document their specific assessment — perhaps answering structured questions about the analysis — before the 'approved' action is available. This makes meaningful review a prerequisite to proceeding, not an optional step. A is wrong: the policy is not the problem — human review is required. The problem is that the system allows the requirement to be satisfied perfunctorily. B is wrong: training informs intent; it does not change system behavior when time pressure is high. D is wrong: disciplinary action addresses individual behavior after the fact; it doesn't change the structural incentive created by a workflow that permits rubber-stamping.

Q3. Which of the following BEST describes the role of a CASB (Cloud Access Security Broker) in enforcing a corporate AI policy?

- A) It reviews AI-generated content for policy compliance before the content is distributed to customers

- B) It identifies traffic to known AI service endpoints, enabling detection and control of unapproved AI tool usage across the organization
- C) It manages the AI procurement review workflow, ensuring vendors complete required security assessments
- D) It provides the audit trail for AI-assisted decisions, satisfying human oversight documentation requirements

Answer: B **Explanation:** B is correct: CASB tools (Microsoft Defender for Cloud Apps, Netskope, Zscaler CASB) detect and control shadow AI adoption by identifying employee traffic to known AI service endpoints — regardless of which device or network path is used. This creates visibility into unapproved tool usage that pure network controls miss and enables policy-based blocking or alerting. A is wrong: CASB operates at the network/access layer, not the content review layer — it detects that data is being sent to an AI service, not what the AI service produces. C is wrong: procurement workflow management is a separate system function; CASB enforces access policy, not procurement process. D is wrong: audit trails for AI-assisted decisions are generated by the AI system itself and documented in workflow systems, not by CASB.

Q4. Samsung's 2023 ChatGPT data leak involved multiple employees independently transmitting proprietary code to an external AI service. Which AI policy control, if implemented before these incidents, would have been MOST effective at preventing the data exposure?

- A) An AI ethics committee review requirement for all generative AI use cases
- B) A mandatory policy acknowledgment signed by employees before they could use any AI tool
- C) DLP rules detecting and blocking transmission of code classified as confidential to external AI service API endpoints, combined with data classification training specific to external AI service interactions
- D) An AI Steering Committee review of the organization's overall AI strategy

Answer: C **Explanation:** C is correct: the Samsung incidents involved data classified as confidential (proprietary semiconductor code) leaving corporate endpoints via API to an external AI service. DLP rules detecting and blocking this transmission would have stopped the data flow regardless of employee awareness or intent. Combined with data classification training specific to AI service interactions (teaching employees that 'proprietary code' means 'do not paste into external AI services'), this addresses both the technical and awareness dimensions of the failure. A is wrong: an ethics committee review is a governance-level control applied to AI system deployment decisions, not individual employee use of external AI tools. B is wrong: policy acknowledgment creates a legal record but does not prevent behavior — employees who sign and later violate the policy still expose data. D is wrong: the AI Steering Committee operates at the strategic level; the failure was operational.

Q5. A developer team is reviewing their company's AI policy for guidance on using GitHub Copilot Enterprise for a new project. The project involves building authentication and authorization logic. Which policy provision is MOST relevant to this scenario?

- A) The data classification restriction prohibiting confidential data input to external AI services
- B) The security-critical code restriction requiring expert security review of AI-generated authentication and authorization code before production use

- C) The human oversight requirement for AI-assisted decisions affecting customers
- D) The labeling requirement for AI-generated content in external communications

Answer: B **Explanation:** B is correct: a mature developer AI policy explicitly restricts AI-generated security-critical code — authentication, authorization, and cryptographic functions — to require expert security review before merge, regardless of which approved tool is used. Authentication logic has particularly high stakes for security failures; AI-generated code in this domain requires expert validation that general code review may not provide. A is wrong: data classification restrictions govern what data goes into AI tools, not what code AI tools generate. The authentication project doesn't necessarily involve transmitting confidential data to Copilot. C is wrong: human oversight requirements for customer-affecting decisions govern decision workflows, not code generation processes. D is wrong: labeling requirements apply to AI-generated communications content, not internally developed code.

Q6. An AI policy includes a list of approved AI tools but no explicit list of prohibited uses. During a tabletop exercise, team members encounter an ambiguous scenario: using an approved AI tool to generate synthetic audio of a client's voice for a product demonstration without the client's knowledge. Which policy gap does this expose?

- A) Absence of a procurement review process for the AI tool used
- B) Absence of an explicit prohibited use list, which would have categorically prohibited generating synthetic voices of real individuals without consent
- C) Absence of a human oversight requirement for audio content generation
- D) Absence of CASB controls to detect AI tool usage

Answer: B **Explanation:** B is correct: the scenario illustrates why an approved tool list alone is insufficient — using an approved tool for a prohibited purpose creates the same governance failure as using an unapproved tool. An explicit prohibition list that categorically prohibits 'generating synthetic voices or images that impersonate real individuals without explicit consent' removes the ambiguity this scenario creates and provides a clear decision rule. A is wrong: the tool is already approved through procurement review; the gap is in use-case governance, not tool approval. C is wrong: human oversight of audio content generation is not the primary control needed here — the issue is categorical prohibition of a specific use, not oversight process. D is wrong: CASB controls detect which tools are used, not whether approved tools are being used for prohibited purposes.

Q7. Which of the following BEST describes the relationship between a corporate AI policy and ISO/IEC 42001 Annex A controls?

- A) ISO/IEC 42001 Annex A controls replace the need for a corporate AI policy in organizations pursuing certification
- B) A corporate AI policy is the internal governance instrument that translates ISO/IEC 42001 requirements into organizational-specific behavioral rules; Annex A provides the control framework that the policy operationalizes
- C) Corporate AI policies apply only to employee behavior; ISO/IEC 42001 applies only to AI system technical controls

D) ISO/IEC 42001 Annex A controls and corporate AI policies govern the same scope and should not overlap

Answer: B **Explanation:** B is correct: ISO/IEC 42001 requires organizations to have an AI policy (clause 5) and implement specific controls (Annex A), but it does not prescribe the specific behavioral rules appropriate to the organization's context, risk tolerance, and culture. The corporate AI policy is the internal instrument that operationalizes the standard's requirements into specific employee-facing rules. The two are complementary: Annex A provides the control framework; the corporate AI policy provides the specific organizational rules that make those controls operational. A is wrong: 42001 requires an AI policy as part of the AIMS — certification doesn't replace the need for policy, it requires it. C is wrong: both 42001 controls and corporate AI policy govern both employee behavior and technical systems. D is wrong: overlap is intentional and expected — the corporate AI policy should implement and embed Annex A control requirements.

Q8. An AI policy was implemented 18 months ago. Since then, the organization has deployed three new generative AI features for customer-facing products, faced a significant AI incident in a peer organization, and the EU AI Act has entered its first compliance phase. The policy has not been updated. Which policy lifecycle mechanism has failed?

- A) Annual comprehensive review (not conducted despite trigger events)
- B) Version control and archiving of superseded policy versions
- C) Employee training on the current policy
- D) AI procurement review for the new generative AI features

Answer: A **Explanation:** A is correct: the scenario describes both time-based (18 months since last update, suggesting an annual review was missed) and event-triggered review failures (peer incident, EU AI Act compliance phase entry, new feature deployment are all events that should trigger policy review). A mature policy lifecycle has both annual reviews and event-triggered reviews — neither has occurred here. B is wrong: version control is about archiving superseded versions; the policy hasn't been updated at all, so this mechanism isn't the relevant gap. C is wrong: training on the current policy is a delivery mechanism; the underlying problem is that the policy itself is outdated regardless of training delivery. D is wrong: AI procurement review governs individual tool approvals; the gap here is in policy currency, not procurement process.

Q9. A corporate AI policy states that 'employees must use AI responsibly and in compliance with applicable laws.' An employee uses a generative AI tool to create a synthetic image of a colleague in a compromising situation and distributes it internally. The employee claims the policy does not prohibit this. What policy design weakness does this scenario most clearly expose?

- A) Absence of a mandatory AI training program for employees
- B) The policy statement is too general to generate a decision — it lacks an explicit prohibited use list that would categorically address synthetic image misuse
- C) Absence of technical controls preventing generative AI image creation on corporate devices
- D) Failure of the AI Review Board to approve the employee's use case before the image was created

Answer: B **Explanation:** B is correct: 'use AI responsibly and in compliance with applicable laws' is not

actionable for the vast majority of employees in ambiguous situations. The policy weakness is the absence of an explicit prohibited use list that would categorically prohibit generating synthetic images that impersonate real individuals without consent — removing the ambiguity the employee exploited. Strong policies are specific enough to generate decisions without requiring employees to interpret principles in novel situations. A is wrong: training reinforces an existing specific prohibition; it cannot substitute for a specific prohibition that doesn't exist. C is wrong: technical controls would help but don't address the policy design weakness — if the policy were specific, enforcement would be clearer. D is wrong: an AI Review Board reviews AI system deployment decisions, not individual employee use cases for existing tools.

Q10. Scenario: *A company's AI policy states that responsibility for AI governance rests with 'the Chief Technology Officer and relevant team leaders.' During an AI incident investigation following a customer-facing AI system failure, the investigation team cannot determine who had authority to approve the original deployment, who was responsible for post-deployment monitoring, or who should have detected the performance degradation that caused the incident. A company's AI policy assigns responsibility for AI governance to the 'Chief Technology Officer and relevant team leaders.' During an AI incident investigation, no one can identify who had authority to approve the AI system's deployment or who was responsible for ongoing monitoring. What policy element is most clearly deficient?*

- A) Procurement requirements — the policy should specify vendor assessment standards
- B) Permitted and prohibited uses — the policy should explicitly categorize the AI system's use case
- C) Governance roles — the policy's role assignment is too vague to create clear accountability; specific named roles with defined responsibilities are required
- D) Human oversight requirements — the policy should specify which decisions require human review

Answer: C **Explanation:** C is correct: 'CTO and relevant team leaders' is not an actionable accountability assignment — it creates diffuse responsibility that produces the accountability gap the investigation exposed. Effective AI policy governance role definitions name specific roles (AI Risk Officer, AI Review Board Chair, Business Unit AI Lead) with specific responsibilities (who approves deployment, who monitors performance, who responds to incidents). When accountability is diffuse, everyone assumes someone else is responsible. A is wrong: procurement requirements address vendor assessment; the gap here is in internal accountability, not vendor evaluation. B is wrong: use-case classification may be a gap, but the immediate investigation problem is inability to identify who is responsible — a governance roles failure. D is wrong: human oversight requirements define when human review is needed; the gap here is in who has authority and responsibility, not whether human review is required.